SECURITY REVIEW · 8 ROUNDS

Security review: Email Header Analyser

Date: 3 Nov 2026 · Scope: index.html · Commit: 7995d5e · Status: High/Medium fixed, Low items open

This report covers a security review of `index.html`, the single-file Email Header Analyser (github.com/Older-Statler/AnalyseHeader), carried out on 3 November 2026. An AI security-review agent found the issues and an AI coding agent fixed them, over eight review rounds. It is an internal, automated review. It is not a formal or third-party audit. All fixes are in the latest commit on `main`.

1. Summary

Scope	One client-side HTML file (`index.html`) with inline CSS and JavaScript. There is no server, build step or dependencies.
Untrusted input	Raw email headers pasted by the user. Anyone who sends the user an email controls these headers.
Reviewed by	AI security-review agent, 8 rounds
Fixed by	AI coding agent
Code version	The latest commit on `main`
Outcome	All High and Medium findings are fixed and were re-tested, including a Medium regression introduced in Round 6. Only Low items, accepted false positives and known limitations remain open (section 11).

Threat model. The review looked for four kinds of attack:

1. **Misleading verdict:** a malicious email crafted so the tool rates it as legitimate (the main risk for a tool like this).
2. **Script injection:** hostile header content running as script or HTML in the page.
3. **Denial of service:** input that freezes or crashes the page.
4. **Data leaving the browser:** pasted headers being sent anywhere.

Severity scale.

Severity	Meaning
High	An attacker can make a malicious message look legitimate, or run code in the page.
Medium	An attacker can noticeably weaken the verdict, or it can be weakened under realistic conditions.
Low	Narrow, hard-to-exploit or limited-impact issues, and hardening.

Three findings were rated between Low and Medium and are labelled **Low–Medium**:

- N3, fixed in Round 2
- the NFKC gaps, fixed in Round 5
- the bidi override issue, fixed in Round 6

All three are fixed. Two Medium findings came up in the later rounds: a regression introduced in Round 6 and found in that round's review, and the odd-space bypass found in Round 7. Both are fixed.

Writing convention. Invisible and text-direction characters are written as `<U+xxxx>` in this report, never as the real characters, so they can't reorder the report's own text.

Scores in the tables below are given as *score/verdict*. Verdicts are *good* ("Looks legitimate"), *warn* ("Some concerns") or *bad* ("Suspicious").

2. Checked and found clean

Area	What was tested	Result
Script injection (XSS)	Every header field displayed by the page was tried with hostile input. All dynamic output passes through `esc()`, which escapes `&`, `<`, `>`, `"` and `'`.	0 leaks
Network requests	Whether the page makes any request while it is used	None. The only outbound links are the AbuseIPDB "reputation" links, which open only when clicked.
Charset handling	`TextDecoder` with arbitrary or invalid charset names in encoded words	Invalid charsets are caught; the raw text is shown instead.
`localStorage`	What is stored and how it is read back	Only the theme preference. After the fixes, only `light` or `dark` is accepted.

3. Round 1: findings and fixes

ID	Severity	Finding	Before → after
H1	**High**	An encoded word (RFC 2047) in the From header could hide a fake address. The address was taken from the decoded text, so the attacker controlled which address was checked.	**92/good** → **65/bad**
H2	**High**	Lower `Authentication-Results` headers, which the attacker can add, filled in any methods missing from the receiver's own header.	**100/good** → **69/warn**
H3	**High**	Header-like lines in the message body were parsed as headers.	**80/good** → **64/warn**

ID	Severity	Finding	Before → after
M4	**Medium**	`ARC-Authentication-Results`, `Received-SPF` and spam-filter headers were trusted, although the sender can write any of them.	**100/good** → passes shown as unverified, verdict capped at warn
L5	**Low**	Regular expressions with quadratic run time froze the page on large input.	6–15 s at 100 KB → 8 ms or less

Fixes:

- **H1:** the address is now read from the raw, undecoded value (the last <…>). Only the display name is decoded.
- **H2:** results come only from the receiver's topmost `Authentication-Results` block. Lower headers are ignored, with a warning if they reuse the receiver's ID.
- **H3:** header parsing stops at the first blank line.
- **M4:**
  - ARC results are used only when there is no `Authentication-Results` header, and only from the highest instance that has a matching `ARC-Seal` whose `cv` is not `fail`.
  - Results from ARC and `Received-SPF` are labelled "Unverified — may be sender-supplied" and earn no credit.
  - The verdict is capped at "Some concerns" when there is no top-level `Authentication-Results` header.
  - Clean spam-filter verdicts are shown as info only. Spam verdicts still count against the message.
- **L5:** the regular expressions were rewritten. Input is capped at 1 MB in total and 64 KB per header value, and a warning appears when anything is cut off.

Hardening added in Round 1:

- **Content-Security-Policy (`<meta>` tag):** `default-src 'none'` blocks all network connections (including `connect-src`) and all external resources. Scripts are allowed only by `sha256` hash, so only the page's own inline script can run.
- **Theme value:** the theme read from `localStorage` is accepted only if it is `light` or `dark`.

4. Round 2: findings and fixes

In Round 2 the reviewer re-tested the Round 1 fixes and found ways around some of them.

ID	Severity	Finding	Before → after
N1	**High**	A forged `Authentication-Results` header placed directly below Gmail's own, with the same authserv-id, was treated as part of the trusted block.	**100/good** → **69/warn**
N2	**Medium**	Two issues with the From header: an angle-address (<…>) hidden inside a comment, and a From value cut short by the 64 KB cap.	**84/good** → **27/bad** (comment); **54/bad** (truncation)

ID	Severity	Finding	Before → after
N3	**Low–Medium**	A fake, higher-numbered ARC instance hid a real failure recorded at an earlier instance.	**100/warn** with nothing failing → **77/warn** with fail warnings
—	**Low**	An address hidden in an encoded word or a comment in the display name did not force a "Suspicious" verdict.	Now forces "Suspicious"
—	**Low**	A `<meta>` CSP can't set `frame-ancestors`, so the page could be embedded in a frame on another site.	Hosting note added (section 12)

Fixes:

- **N1:** extra `Authentication-Results` headers with the same authserv-id count only if they sit *above the topmost `Received` header*. A sender's headers can never appear there. Being next to the first header is no longer enough. Other same-ID headers trigger a "Possible forged Authentication-Results" warning.
- **N2:**
  - Comments are removed before the address is located, and are no longer shown as part of the display name.
  - A new "Ambiguous From header" check flags: more than one `<`, unbalanced quotes or comments, or an `@` outside the address.
  - From, Reply-To, Sender and `Authentication-Results` values over 64 KB are not parsed at all, and an oversized From forces "Suspicious".
- **N3:** fail, softfail, hardfail and permerror results from *any* source (ignored `Authentication-Results` headers and every ARC instance) are now reported as "An earlier server recorded … fail" warnings. Pass results from those sources are still never trusted.

5. Round 3: result

Verdict: OK to commit. Every finding from Rounds 1 and 2 was re-tested and confirmed fixed. Three Low items were left open and were fixed in Round 4.

The reviewer agreed with three judgement calls:

Decision	Reason
Failures recorded by earlier servers are capped at a warning, not Fail.	Legitimate forwarding and mailing lists often break SPF or DKIM at an earlier hop.
An ambiguous From header on its own doesn't force "Suspicious".	It is still a 30-point Fail and stops the verdict from being "Looks legitimate". Forcing "Suspicious" would add false positives for unusual but legitimate formatting.
Comments are dropped from the displayed name.	A comment can't be used to make the displayed sender look different from the real one.

6. Round 4: fixes for the Round 3 open items

The coding agent fixed the three Low items left open after Round 3, and the review agent re-checked them. **Verdict: OK to commit.** No regressions were found, and every earlier fix still passes.

ID	Severity	Finding	Fix	Before → after
(a)	**Low**	Full-width look-alike characters in the display name got past the spoofing check.	Display-name checks run on Unicode NFKC-normalised text. The name is still shown as written.	`<service@paypal.com>`: **92/good** → **27/bad**. U+FE6B, U+2024, U+FF0E and zero-width characters inside encoded words are also caught (**65/bad**).
(b)	**Low**	If the receiving server added no `Authentication-Results` header, a sender-added one was treated as the topmost.	`X-Received` counts as a hop. With no `Received` or `X-Received` header, results are shown as unverified and the verdict is capped at warn. A note under the auth cards says results assume the receiver added the topmost `Authentication-Results`.	No hop: **92/good** → **92/warn**. `X-Received` only, above a forged split `Authentication-Results`: **94/good** → **63/warn**.
(c)	**Low**	An address with a quoted local-part in the display name wasn't detected.	A linear `indexOf` scan flags any `@domain` in the display name whose organisational domain differs from From.	`"a"@evil.com <service@paypal.com>`: **84/good** → **54/warn**

How far fix (b) goes. The hop check only helps when a pasted snippet has no `Received` header at all. An attacker can forge `Received` headers below their fake `Authentication-Results`, and the page can't tell them from real ones. Treat (b) as a known limitation, not real protection (see item 3 in section 11).

Judgement calls the reviewer agreed with (c): social handles such as `@anadev` (no dot and letter TLD) are not flagged, and nor are subdomains of the From domain.

Re-checks:

Area	Result
Performance	Worst NFKC expansion case (60,000 × U+FDFA) runs in 22 ms. No catastrophic regex backtracking (ReDoS).
XSS	0 leaks
CSP	`script-src` hash regenerated for the updated script

7. Round 5: fixes for Round 4 open items 1 and 4

The coding agent fixed two of the open items from Round 4: item 1 (characters NFKC doesn't fold) and item 4 (score shown next to a capped verdict). The review agent re-checked them. **Verdict: OK to commit.** No regressions were found.

Item	Severity	Fix	Before → after
1	**Low–Medium**	The display-name scan now: • strips default-ignorable characters • maps U+3002, U+FF61, U+FF0E and U+0701 to . • accepts TLDs made of any Unicode letters (a dot is still required)	• U+3002, U+FF61 or U+0701 as dots, or a zero-width space or soft hyphen in the TLD: **100/good** → **49/bad** ("hides", forced Suspicious). The reviewer also confirmed U+FE52, variation selectors, LRI… PDI isolates, tag characters and combining marks inside the TLD give **49/bad**. • A Cyrillic o in the TLD, or a real `.pф` TLD: **100/good** → **70/warn** ("contains").
4	Cosmetic	When a rule forces the verdict down, the score is clamped to match (at most 79 for warn, 49 for bad). The verdict card shows "Score capped:" and the reason.	No hop: **92/warn** → **79/warn**. The reviewer found no case where the score and verdict still disagree. The reason strings are fixed text and are escaped.

Judgement call the reviewer agreed with: look-alikes that are visible in the name (such as a Cyrillic letter) count as "contains a different address", not "hides". An optional refinement is to treat labels that mix scripts (for example Latin and Cyrillic in one label) as "hides".

Re-checks:

Area	Result
Performance	27 ms or less in the worst cases. No ReDoS.
XSS	0 leaks
CSP	`script-src` hash regenerated
False positives	None for `Dr. Ana Pérez`, `J.R.R. Tolkien`, `ACME Inc. – info@acme.com` (From `acme.com`), a subdomain of From, names with emoji, or `Meet @ 10.30am`

8. Round 6: fixes for Round 5 open items 1 and 4

The coding agent fixed the bidi override issue (open item 1) and added the mixed-script refinement. It also tried a change to stop false positives for social handles (open item 4). The review agent found that change caused a regression, and it was reverted.

Change	Severity	Fix	Before → after
Bidi overrides (item 1)	**Low–Medium**	U+202A–U+202E and U+2066–U+2069 in the From display name trigger "Display name uses text-direction controls" and force Suspicious. These characters are shown as visible markers such as `[U+202E]` wherever header text is displayed. Untrusted text is isolated with CSS `unicode-bidi: isolate` and `<bdi>`. The plain direction marks LRM, RLM and ALM are	RLO-reversed address (`PayPal <U+202E>moc.lapyap@ecivres <a@evil.com>`): **100/good** → **49/bad**. Arabic and Hebrew names stay **100/good**.

Change	Severity	Fix	Before → after
		allowed.	
Mixed-script domain labels	Refinement	A domain label in the display name that mixes alphabets, such as Latin and Cyrillic in `paypal` or `com`, counts as "hides" and forces Suspicious. Labels in a single script, such as `.pф`, are unchanged.	Cyrillic `o` in the TLD: **70/warn** → **49/bad**
Handle false positives (item 4)	**Medium regression**, reverted	The first attempt required a part before the `@` for "contains". The reviewer found it let `PayPal Support @paypal.com <a@evil.com>` through. The user chose to revert it. Any visible `@domain` with a dot and a letter TLD that differs from From gives "contains" (warn) again.	Regression: **70/warn** → **100/good**. After the revert, handles are flagged as warn again. `Meet @ 10.30am` is still not flagged.
Unusual spaces before `@`	—	An unusual space (NBSP, thin, hair space and similar) directly before an `@` counts as "hides".	**100/good** → **49/bad**
Invisible characters in source code	Hardening	Regular expressions that contained literal invisible or bidi characters were rewritten with `\u` escapes. Literal characters like these can make source code read differently from how it runs (the "Trojan Source" problem).	—

9. Round 7: follow-up on Round 6

The review agent re-checked Round 6 and found two more issues. Both were fixed. **Final verdict: OK to commit.** No regressions were found.

ID	Severity	Finding	Fix	Before → after
R7-1	Medium (blocking)	An odd space after the `@` or inside the domain still hid an address, as in `service@<U+200A>paypal.com`.	Odd spaces are deleted before NFKC normalisation. These are `\p{Zs}` characters other than an ordinary space, plus U+2800, U+180E, U+2028 and U+2029. An address that only appears after deleting them counts as "hides". The odd-character test checks both sides of the `@`.	**100/good** → **49/bad**
R7-2	**Low**	A U+2028 or U+2029 inside a header line merged that line into the previous header. A sender could use this to hide their own Reply-To, X-Mailer or List-Unsubscribe from the checks.	Lines containing these characters are no longer merged into the previous header. A line containing only U+2028 no longer ends the header block.	Fixed
—	Documentation	The README said the page "could not send your headers anywhere". That overstated the CSP, which blocks	README wording corrected.	—

ID	Severity	Finding	Fix	Before → after
		network requests and external resources but not navigation.		

Re-checks:

Area	Result
Performance	26 ms or less in the worst cases. No ReDoS.
XSS	0 leaks
CSP	`script-src` hash regenerated

10. Round 8: blank-line fix

The coding agent fixed open item 1 from Round 7. The review agent re-checked it. **Verdict: OK to commit.** No regressions were found.

Item	Severity	Fix	Before → after
1	Low	Any line that contains only whitespace now ends the headers, except a line containing only U+2028 or U+2029. A separator line made of NBSP characters in a webmail copy now ends the headers correctly.	H3-style injection after a separator line of only NBSP: the body's forged `Authentication-Results` was parsed → nothing from the body is parsed (**64/warn**, the same as the original H3 test)

Re-checks:

Area	Result
Behaviour kept	Lines of only U+2028 or U+2029 still don't end the headers. CRLF and CR line endings, blank lines of spaces or tabs, and folded headers behave as before.
Performance	9 ms or less. No ReDoS.
XSS	0 leaks
CSP	`script-src` hash regenerated

Reviewer note: lines of only U+FEFF. A line containing only U+FEFF also ends the headers, because the whitespace class `\s` includes it. The reviewer rated this harmless:

- Such a line can't be a folded continuation.

- Standard parsers also treat it as the end of the headers.
- Only the sender's own headers below it are affected.
- Hiding the From header this way gives "Missing From header" (bad).

11. Open items

Resolved:

- **Bidi overrides:** fixed in Round 6.
- **Handle false positives:** reverted by design. Handles in display names give a warning, which is accepted as a false positive (item 4 below).
- **Item 1 (separator lines of NBSP, VT or FF):** fixed in Round 8 (section 10).

#	Severity	Issue	Example / impact	Suggested fix
2	Low (theoretical, not tested in a browser)	The direction marks RLM and ALM, which are allowed, could visually reorder the parts around an `@` without using the flagged controls.	Display isolation limits the effect on the rest of the page.	—
3	Low (known limitation)	The hop check can be passed with forged `Received` headers.	The page can't tell forged hops from real ones.	None in the page. Paste headers straight from your own mail client. A possible feature: an optional trusted authserv-id that the user configures and that is stored locally.
4	Accepted false positives	Harmless names that are flagged	• social handles in display names (warn) • NBSP around an `@` followed by words, as in `Sales<U+00A0>@<U+00A0>Acme Ltd. UK` (bad) • Latin mixed with Han or Kana in one label (bad)	Accepted to keep the spoofing checks strict.
5	Known limitations	Display-name cases that are not flagged	• look-alikes in a single script, such as an all-Cyrillic label • some dot look-alikes that aren't mapped, such as U+2E3C and U+00B7 • TAB, NEL, VT or FF before an `@` (warn only) • circled letters • spelled-out addresses (`service at paypal.com`) • `service@paypal.com.evil.c`	Would need the Public Suffix List, confusable-character tables or brand matching.

#	Severity	Issue	Example / impact	Suggested fix
			`om` when From is `evil.com` • a brand name with no address (`PayPal <a@evil.com>`) • the built-in organisational-domain rules, which treat `paypal.github.io` and `evil.github.io` as the same organisation	
6	Low (new; existed before Round 8, not a regression)	A line containing only whitespace that starts with a space or tab ends the header block, while some mail servers may treat it as a folded continuation. A sender could use this to hide their own later headers (Reply-To, X-Mailer, List-Unsubscribe) from the analysis, while the mail client still sees them.	Limited: only headers the sender wrote are affected, and it depends on how servers behave, which was not tested.	When such a line is directly followed by a header-like line, show a warning such as "possible hidden headers after a whitespace-only line". Don't continue parsing past the line, because that could reopen body injection.

12. Hosting recommendations

1. **Send `frame-ancestors` as an HTTP header.** A `<meta>` CSP can't set it, so configure the host to send:

```
Content-Security-Policy: frame-ancestors 'none'
```

This stops other sites from embedding the page in a frame (clickjacking).

2. **Keep the CSP hash current.** Whenever the inline `<script>` changes, regenerate its `sha256` hash and update the `script-src` value in the CSP. Otherwise the browser will block the script. The command is in the README ("Contributing / editing the page") and in a comment above the CSP `<meta>` tag.

13. Limitations of this review

- **The tool does no cryptographic verification.** It doesn't check DKIM signatures or ARC seals, and makes no DNS lookups. It reports what receiving servers recorded. The review tested how well the tool resists forged or misleading headers. It could not make the tool's results authoritative.
- **It trusts the topmost `Authentication-Results`.** The tool can't tell real `Received` headers from forged ones. Its results are only as trustworthy as the source of the pasted headers.
- **The CSP limits what the page can do.** It blocks network requests and external resources, but not navigation. This report doesn't claim that sending data out is impossible.
- **Look-alike coverage is partial.** Display-name cleanup handles full-width forms, invisible characters and odd spaces, common dot look-alikes, mixed-script labels and text-direction controls, but not every look-alike character (section 11, items 2 and 5).
- **Heuristic parsing.** Parsing of `Received` headers, TLS detection, organisational-domain alignment and scoring are all based on pattern matching. Unusual but legitimate formats may still be misread, and other

bypasses may exist beyond those tested.

- **Testing method.** Findings were reproduced and re-tested with Node.js test scripts that ran the page's parsing and analysis code, plus headless Firefox for rendering, XSS and CSP behaviour. Other browsers were not tested, and some display effects (section 11, item 2) were not tested in a browser. How real mail servers handle whitespace-only folded lines (section 11, item 6) was not tested.
- **Automated review.** The review and fixes were both carried out by AI agents. No independent human security professional has assessed the page.

Internal, automated review. Not a formal or third-party audit.